SEKOLAH TINGGI TEKNOLOGI TERPADU NURUL FIKRI
Program Studi Teknik Informatika | Mata Kuliah DevSecOps

PANDUAN PRAKTIKUM KELOMPOK

DAST dengan OWASP ZAP

Pertemuan 6 — Dynamic Application Security Testing

Target Aplikasi

URL : https://cyphera-vulnlab.vercel.app/
Aplikasi : SnipVault — Platform berbagi kode snippet & catatan
Kelompok : 4–6 mahasiswa
Durasi : 90–100 menit
Dosen : April Rustianto, S.Komp., M.T., CCIE

1. Tujuan Praktikum

Setelah menyelesaikan praktikum ini, mahasiswa mampu:

1. Mengoperasikan OWASP ZAP untuk melakukan Dynamic Application Security Testing (DAST) pada aplikasi web nyata.
2. Menerapkan minimal 4 metode scanning ZAP secara sistematis: Traditional Spider, AJAX Spider, Passive Scan, dan Active Scan.
3. Mengidentifikasi dan mengklasifikasikan vulnerability berdasarkan severity (High, Medium, Low, Informational).
4. Menganalisis vulnerability yang ditemukan dan memahami dampaknya terhadap keamanan aplikasi.
5. Menyusun laporan temuan vulnerability lengkap dengan bukti dan rekomendasi remediasi.

2. Persiapan Sebelum Lab

2.1 Persyaratan Perangkat Lunak

> ⚠ **PENTING — Pastikan ini sudah terinstall sebelum lab dimulai**
> Setiap anggota kelompok WAJIB menginstall OWASP ZAP sebelum pertemuan.
> Minimal 1 laptop per kelompok yang terinstall ZAP dan terhubung internet.

- ☐ OWASP ZAP 2.15.x (Desktop Edition)
  - Download: https://www.zaproxy.org/download/
  - Pilih installer sesuai OS: Windows (.exe), macOS (.dmg), Linux (.sh)
- ☐ Browser (Chrome atau Firefox) — untuk manual browsing
- ☐ Koneksi internet aktif
- ☐ ZAP FoxyProxy atau konfigurasi proxy browser (opsional, untuk manual explore)

2.2 Konfigurasi Awal ZAP

6. Buka OWASP ZAP → pilih "Start a new session"
7. Konfigurasi proxy: Tools → Options → Local Proxies → Port 8080
8. Verifikasi proxy aktif di status bar (kiri bawah: "localhost:8080")
9. Masukkan URL target: ketik di address bar ZAP → https://cyphera-vulnlab.vercel.app/

2.3 Profil Aplikasi Target

Aplikasi target adalah SnipVault — platform berbagi kode snippet dan catatan dengan fitur:

Endpoint / Fitur	Metode	Potensi Vulnerability
/	GET	Informasi versi framework, konfigurasi
/login	POST	SQL Injection, Brute Force, CSRF
/register	POST	SQL Injection, Mass Assignment, Weak Password Policy
/search	GET	Reflected XSS, SQL Injection (parameter q)
/note/{id}	GET	IDOR (Insecure Direct Object Reference)
/tools → Link Preview	POST	SSRF (Server-Side Request Forgery)
/tools → Note Preview	POST	SSTI (Server-Side Template Injection) — ERB syntax
/tools → Upload	POST	Unrestricted File Upload, Stored XSS
/dashboard	GET	Broken Access Control, Session Fixation

Demo Credentials (lihat README aplikasi)
Akun tersedia di halaman README aplikasi target.
Coba registrasi akun baru di /register untuk pengujian authenticated scan.
Username: [sesuai README] | Password: [sesuai README]

3. Pembagian Peran Kelompok

Setiap kelompok (4–6 orang) membagi peran sebagai berikut. Rotasi peran boleh dilakukan antar sesi.

Peran	Jumlah	Tanggung Jawab Utama
Ketua / Koordinator	1 orang	Memimpin diskusi, memastikan jadwal, menyatukan laporan akhir
ZAP Operator	1–2 orang	Menjalankan OWASP ZAP, mengatur konfigurasi scan, mengeksekusi setiap metode
Analis Vulnerability	1–2 orang	Menganalisis setiap alert ZAP, menilai severity dan dampak, menulis deskripsi
Dokumentator / Reporter	1 orang	Merekam screenshot, menulis laporan, menyusun rekomendasi remediasi

Tips Koordinasi
Gunakan satu laptop sebagai "ZAP station" yang terhubung ke layar/proyektor.
Anggota lain membantu mencatat, menganalisis alert, dan menulis laporan secara paralel.
Buat grup chat kelompok untuk berbagi screenshot dan temuan secara real-time.

4. Langkah-Langkah Praktikum

Ikuti urutan tugas berikut. Setiap tugas menggunakan metode ZAP yang berbeda. Dokumentasikan setiap langkah dengan screenshot.

Tugas A — Reconnaissance & Spider (Traditional Spider) ⏱ 15 menit

Tujuan: Memetakan seluruh struktur URL aplikasi target secara otomatis

10. Buka ZAP → tab "Quick Start" atau masuk ke Sites panel
11. Klik kanan pada URL target di panel Sites → "Spider..."
12. Pada dialog Spider, pastikan "Start URL" = https://cyphera-vulnlab.vercel.app/
13. Centang opsi "Recurse" dan klik "Start Scan"
14. Tunggu hingga selesai (progress bar 100%)
15. Lihat panel "Spider" → tab "URLs Found" → catat semua URL yang ditemukan
16. Catat jumlah URL unik yang ditemukan di tabel temuan

Yang Perlu Didokumentasikan

- Screenshot panel "URLs Found" setelah Spider selesai
- Daftar endpoint penting yang ditemukan (misal: /login, /search, /tools, /note/1)
- Total jumlah URL yang di-crawl
- Apakah ada URL yang tidak bisa diakses (4xx/5xx)?

Tugas B — AJAX Spider — Single Page Application Crawling ⏱ 15 menit

Tujuan: Menemukan URL dan endpoint yang hanya muncul setelah JavaScript dieksekusi

17. Di ZAP: Tools → AJAX Spider atau klik kanan Sites → "AJAX Spider…"
18. Isi "Starting Point URL": https://cyphera-vulnlab.vercel.app/
19. Pilih browser: "Firefox (Headless)" atau "Chrome (Headless)"
20. Klik "Start Scan" dan tunggu proses selesai (~2–5 menit)
21. Bandingkan hasil AJAX Spider dengan Traditional Spider:
    - URL baru apa yang ditemukan AJAX Spider tapi tidak ditemukan Traditional Spider?
    - Berapa total URL yang berhasil di-crawl?
22. Screenshot panel hasil AJAX Spider

📋 **Yang Perlu Didokumentasikan**
- Screenshot hasil AJAX Spider (panel "URLs Found")
- Perbandingan: Traditional Spider vs AJAX Spider (tabel atau daftar)
- Apakah ada endpoint JavaScript-rendered yang baru ditemukan?

Tugas C — Passive Scanning — Analisis Traffic Pasif ⏱ 15 menit

Tujuan: Mendeteksi vulnerability dari traffic HTTP tanpa mengirim request berbahaya

Passive scanning berjalan otomatis di background selama browsing. Ikuti langkah berikut:

23. Pastikan ZAP proxy aktif (port 8080)
24. Konfigurasi browser untuk menggunakan proxy localhost:8080 (gunakan FoxyProxy atau settings manual)
25. Browse secara manual melalui browser semua fitur aplikasi:
    - Kunjungi homepage, halaman /search, /login, /register
    - Coba fitur /tools (Link Preview, Note Preview, Upload)
    - Buka beberapa note: /note/1, /note/2, /note/3
26. Selama browsing, ZAP otomatis memindai traffic (tab "Alerts" bertambah)
27. Setelah selesai, lihat tab "Alerts" → catat semua temuan passive scan
28. Klik setiap alert untuk melihat detail: evidence, solution, reference

Yang Perlu Didokumentasikan

- Screenshot tab Alerts setelah passive scanning
- Daftar semua alert dengan severity (High/Medium/Low/Informational)
- Detail salah satu alert Medium atau High (screenshot detail alert)
- Alert yang paling kritis menurut kelompok dan alasannya

Tugas D — Active Scanning — Pengujian Aktif ⏱ 20 menit

Tujuan: Mengirim payload serangan untuk menemukan vulnerability secara aktif

> ⚠ **PERINGATAN**
> Active Scan mengirim payload berbahaya (XSS, SQLi, dll) ke server target.
> HANYA lakukan pada aplikasi yang sudah diberi izin untuk dites (cyphera-vulnlab adalah lab resmi).
> JANGAN gunakan Active Scan pada aplikasi production atau milik pihak lain.

29. Di ZAP, klik kanan pada URL target di Sites panel → "Active Scan…"
30. Pilih "Starting Point": https://cyphera-vulnlab.vercel.app/
31. Policy: gunakan "Default Policy" (semua scanner aktif)
32. Klik "Start Scan"
33. Pantau progress di panel "Active Scan" (bisa memakan waktu 5–15 menit)
34. Selama scan berjalan, perhatikan:
    - Tab "Alerts" — temuan baru yang muncul real-time
    - Panel "Spider" — request yang dikirim
35. Setelah selesai, buka tab "Alerts" → filter berdasarkan severity
36. Identifikasi temuan High dan Medium → klik untuk melihat payload yang digunakan

> 📋 **Yang Perlu Didokumentasikan**
> • Screenshot panel Active Scan (progress 100%)
> • Screenshot tab Alerts setelah Active Scan (dikelompokkan per severity)
> • Detail minimal 2 temuan High/Medium: nama vulnerability, URL, parameter, payload, evidence
> • Bandingkan: Alert baru apa yang muncul setelah Active Scan (vs Passive Scan)?

Tugas E — Pengujian Manual Target Spesifik ⏱ 15 menit

Tujuan: Menguji endpoint berisiko tinggi secara terarah

Kelompok memilih MINIMAL 2 dari 3 pengujian manual berikut:

E.1 — Uji IDOR pada /note/{id}

37. Login sebagai user biasa (registrasi jika belum ada akun)
38. Buat sebuah private note
39. Catat ID note kamu
40. Logout, lalu coba akses /note/{id} milik user lain (ganti angka ID secara manual)

41. Apakah kamu bisa melihat note orang lain? Dokumentasikan hasilnya

E.2 — Uji SSTI pada /tools (Note Preview)

42. Buka https://cyphera-vulnlab.vercel.app/tools
43. Pada fitur "Note Preview", masukkan payload ERB sederhana:

```
<%= 7 * 7 %>
```

44. Jika output menampilkan "49" → SSTI terkonfirmasi!
45. Coba payload yang lebih advanced (misal: info OS, baca file)
46. Screenshot hasil dan catat severity

E.3 — Uji SSRF pada /tools (Link Preview)

47. Buka https://cyphera-vulnlab.vercel.app/tools
48. Pada fitur "Link Preview", masukkan URL internal:

```
http://localhost/
http://169.254.169.254/latest/meta-data/
```

49. Perhatikan respons server — apakah ada data internal yang bocor?
50. Coba juga masukkan URL eksternal biasa untuk referensi baseline
51. Screenshot dan analisis perbedaan respons

Yang Perlu Didokumentasikan

- Pengujian mana yang dipilih (E.1, E.2, E.3)
- Screenshot langkah demi langkah untuk setiap pengujian
- Hasil: apakah vulnerability terkonfirmasi? (Ya/Tidak + bukti)
- Dampak jika dieksploitasi di aplikasi production

Tugas F — Membuat Laporan HTML dengan ZAP ⏱ 10 menit

Tujuan: Mengekspor laporan resmi OWASP ZAP

52. Di ZAP: Report → Generate Report
53. Pilih template: "Traditional HTML Report" atau "Modern HTML Report"
54. Isi metadata laporan:
    - Report Title: "DAST Report — SnipVault Pertemuan 6"
    - Report Description: nama kelompok dan anggota
55. Pilih semua risk levels: High, Medium, Low, Informational
56. Klik "Generate Report" → simpan file .html
57. Buka file laporan di browser → screenshot halaman ringkasan (Summary)
58. Attach file laporan HTML ke dokumen pengumpulan

5. Format Laporan Kelompok

Laporan dikumpulkan dalam format PDF atau DOCX. Struktur laporan harus mengikuti template berikut:

5.1 Struktur Laporan

59. Cover Laporan — Nama kelompok, NIM anggota, tanggal
60. Ringkasan Eksekutif (Executive Summary) — Deskripsi singkat target, total vulnerability per severity
61. Metodologi — Metode scanning yang digunakan dan urutan pengujian
62. Temuan Vulnerability — Detail setiap vulnerability (gunakan tabel di bawah)
63. Rekomendasi Remediasi — Solusi teknis untuk setiap temuan
64. Lampiran — Screenshot ZAP, laporan HTML ZAP

5.2 Template Tabel Temuan

Isi tabel berikut untuk setiap vulnerability yang ditemukan (tambah baris sesuai kebutuhan):

No	Nama Vulnerability	Endpoint	Severity	Deskripsi & Bukti
1				

No	Nama Vulnerability	Endpoint	Severity	Deskripsi & Bukti
2				
3				

Keterangan severity: High | Medium | Low | Informational

5.3 Template Rekomendasi Remediasi

Untuk setiap vulnerability High atau Medium, sertakan rekomendasi dengan format:

Contoh Format Rekomendasi

Vulnerability : SQL Injection pada /login (parameter username)
Severity : High
Dampak : Penyerang dapat bypass autentikasi atau dump database
Remediasi : Gunakan prepared statements / parameterized queries.
Validasi dan sanitasi input di sisi server.
Terapkan principle of least privilege pada database user.

Pengumpulan

Deadline : Akhir pertemuan atau sesuai arahan dosen
Format : PDF / DOCX + file laporan HTML dari ZAP
Cara kirim : Upload ke LMS atau email ke dosen
Nama file : Kelompok-[Nomor]_DAST_P6_[NamaMatkul].pdf

7. Referensi & Sumber Belajar

- OWASP ZAP Official Documentation: https://www.zaproxy.org/docs/
- OWASP Top 10 (2021): https://owasp.org/Top10/
- OWASP Testing Guide v4.2: https://owasp.org/www-project-web-security-testing-guide/
- PortSwigger Web Security Academy: https://portswigger.net/web-security
- ZAP Scanning Scripts & API: https://www.zaproxy.org/docs/api/
- OWASP Vulnerability Descriptions: https://owasp.org/www-community/vulnerabilities/